



Requisição a inteligência

Entender a cadeia de ataque do Ransoware **Dragon Force** feito pelo grupo **Scattered Spider** para impedir sua propagação futura

Data do ataque: Em Abril de 2025

Feedback e melhoria:

Entrada SOC: Notado que o bloqueio de acessos administrativos via SSH causou falsos positivos em tarefas de manutenção legítimas.

Melhoria: O próximo ciclo de defesa adicionará um filtro por IPs de origem conhecidos do provedor de nuvem e exigirá pontuação de confiança "Alta" para bloqueio automático de hashes vistos <10x globalmente.

Saídas e Canais:

Relatório Tático: Enviado ao SOC em 25/04/2025 09:00 UTC, **Listado:**
Link para patch da **CVE-2025-22224**.

Feedback

Planejamento e Direção

Dissiminação



ia
e do
eito
r
o
e

Origem

O incidente com a **Marks & Spencer** (M&S) em abril de 2025 foi um dos a paralisando operações críticas e expondo dados de milhões de clientes

Indicadores de Comprometimento (IOCs)

Hashes de Arquivos (SHA256):
ed492db95034ca288dd52df88e3ce3ec7b146ffd854a394ac187f0553ef9666a5830602f068427f71b9e67a06c860c2380f2d4e8c187f54c553ef966d921

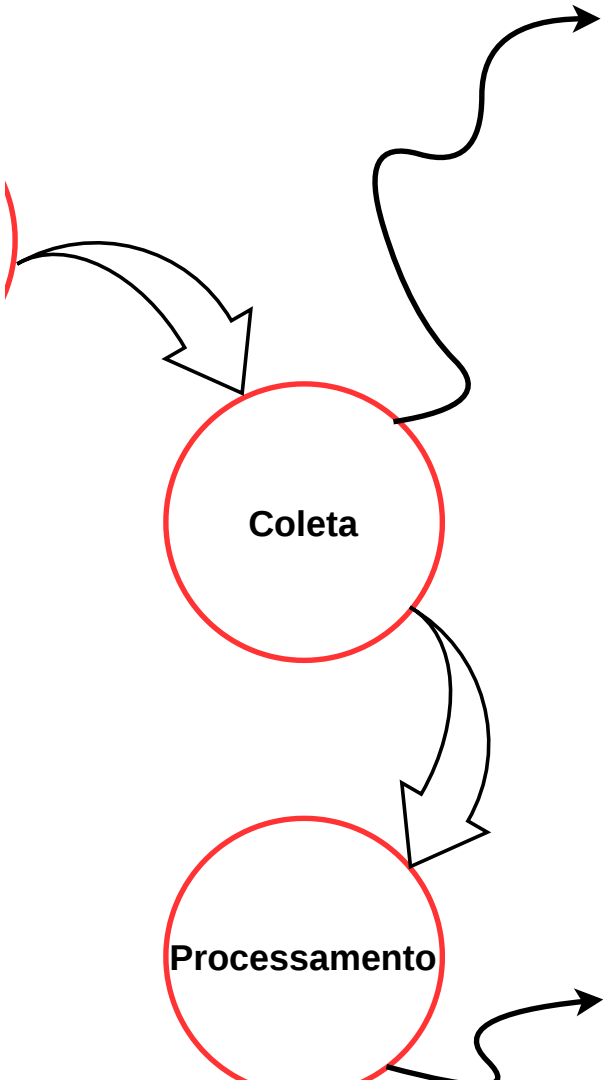
Domínios de Comando e Controle (C2):
mands-update-portal.com (Utilizado para phishing e captura de credenciais)
staff-mands-auth.net (Portal falso para bypass de MFA).

Endereços IP:
185.193.38.12 (Infraestrutura de exfiltração para servidores Mega.nz).
45.227.253.114 (Proxy de acesso via túnel SSH para movimento lateral).

Extensão de Arquivo Criptografado:
Os arquivos afetados receberam a extensão .dragon ou .force.

Links e Referências Técnicas

CISA Advisory: Scattered Spider and DragonForce IOCs and TTPs
Trend Micro Research: Analysis of DragonForce Ransomware Attacks on I



Normalização

TTPs (Táticas, Técnicas e Procedimentos), domínios C2 e extensões de criptografia foram extraídos para um painel de inteligência de ameaças.

Os hashes dos arquivos relatados foram analisados e inseridos em uma coluna CSV intitulada "DragonForce-20250424-Hashes".
Extração de Atributos Críticos: O identificador CVE-

ataques de ransomware mais impactantes do ano no setor de varejo,

sd9 (Payload principal do ransomware DragonForce).
.34 (Ferramenta de exfiltração de dados Rclone modificada).

is de funcionários).

Retail Systems

Hashes SHA256 dos binários conhecidos do DragonForce.

Assinaturas de rede para detecção de tráfego C2 do grupo Scattered Spider.

Evento MISP publicado no mesmo dia com todos os IOCs e notas elaboradas de TTPs.

Analise

Correlação e percepção

Correlação entre o padrão de exploração de vulnerabilidades (anomalias de autenticação em hosts ESXi) e a automação identificados na rede da M&S.

Referenciamento cruzado de hashes no VirusShare para a propagação do ransomware em múltiplos hosts em menos de 48 horas.

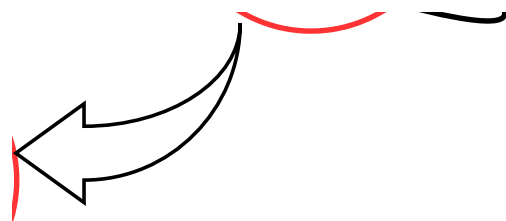
Mapped the kill chain:

Acesso inicial: Engenharia social via suporte técnico e exploração do CVE-2025-22224.

Execução: Deploy do binário dragon.exe (implant) em servidores virtualizados.

Movimentação Lateral: Uso de ferramentas de movimentação lateral via controladores de domínio comprometidos.

Impacto: Criptografia de sistemas de estoque de dados seguida pela publicação de dados de clientes e vazamentos do grupo.



lo **CVE-2025-22224**
i) com os scripts de

rusTotal, identificando
s setores de varejo em

orte técnico (vishing) e

payload DragonForce)

as de túnel SSH e
domínio

que e logística,
tes no blog de

Hashes .Extração de Atributos Críticos: O identificador CVE-2025-22224, a URL do patch da VMware e os fragmentos de código do exploit foram consolidados em uma planilha técnica para priorização de correção em servidores remanescentes.

Catalogação de Artefatos: Os hashes de arquivos relatados em blogs de segurança e telemetria foram analisados e inseridos em uma coluna de CSV rotulada como “DragonForce-20250424-Hashes” para facilitar o bloqueio via EDR.

Padronização Temporal: Todos os registros de logs de acesso e timestamps de execução de comandos foram convertidos e padronizados para UTC (partindo de BRT/BST), garantindo a correlação precisa da linha do tempo entre diferentes fusos horários da infraestrutura global.

Mapeamento de Táticas: As técnicas de engenharia social e movimento lateral foram mapeadas para a matriz MITRE ATT&CK, permitindo a criação de alertas de detecção comportamental baseados em eventos de sistema.

